Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	Password cracking e risposta a WannaCry

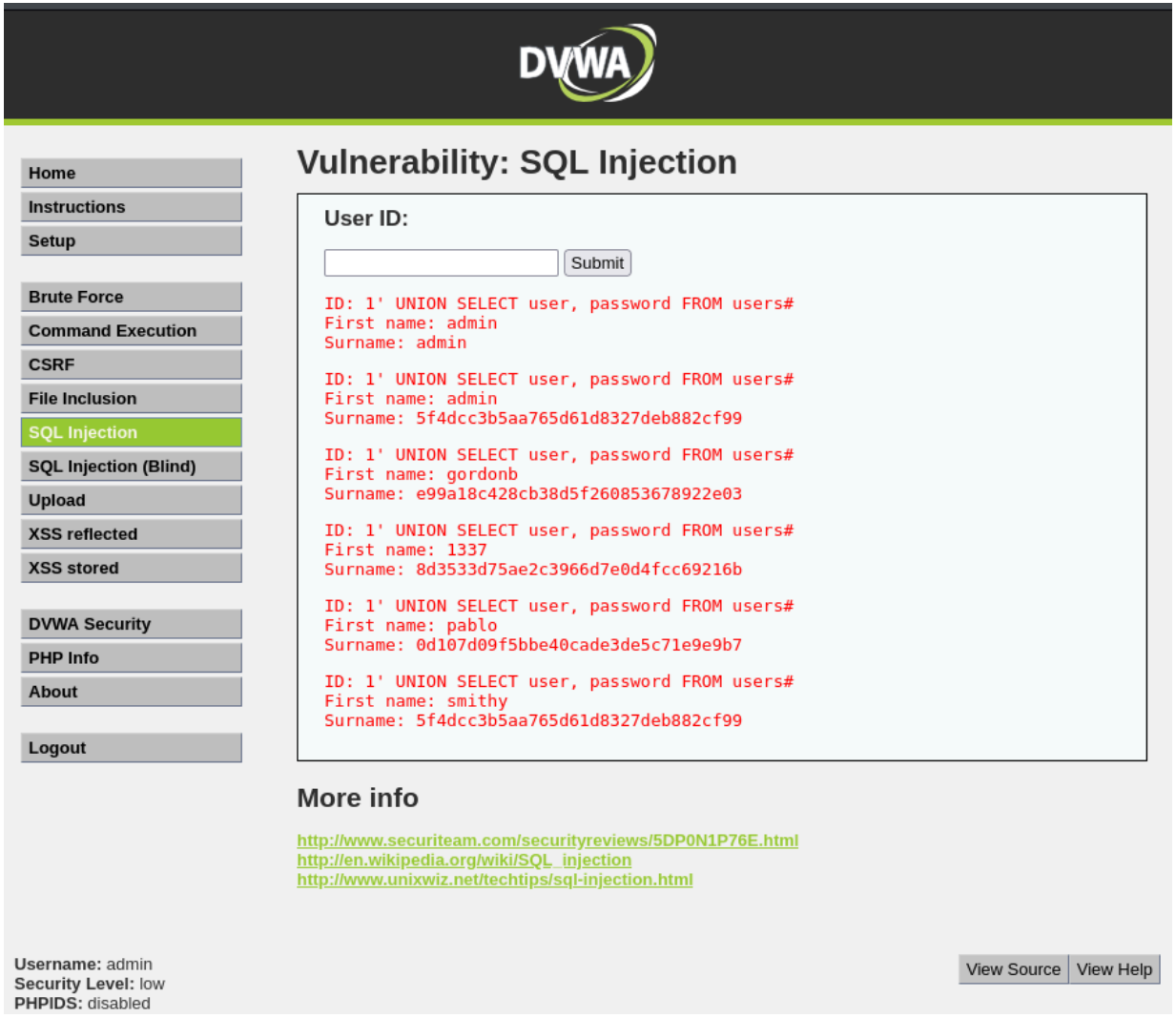
Password cracking con John the Ripper e risposta a WannaCry

Obiettivo e ambiente

L'attività è stata svolta nel laboratorio didattico DVWA con Security Level impostato su Low. L'obiettivo era verificare come gli hash di password ottenuti dalla precedente SQL Injection possano essere controllati con John the Ripper e un attacco a dizionario. È inclusa anche una parte teorica facoltativa sulla risposta a un'infezione da WannaCry.

1 Recupero degli hash dal database didattico

La precedente SQL Injection ha mostrato i valori delle colonne user e password della tabella users. Sono stati ottenuti cinque hash; il primo e l'ultimo sono identici, quindi corrispondono alla stessa password. Gli hash sono stati copiati in un file locale per la verifica successiva.

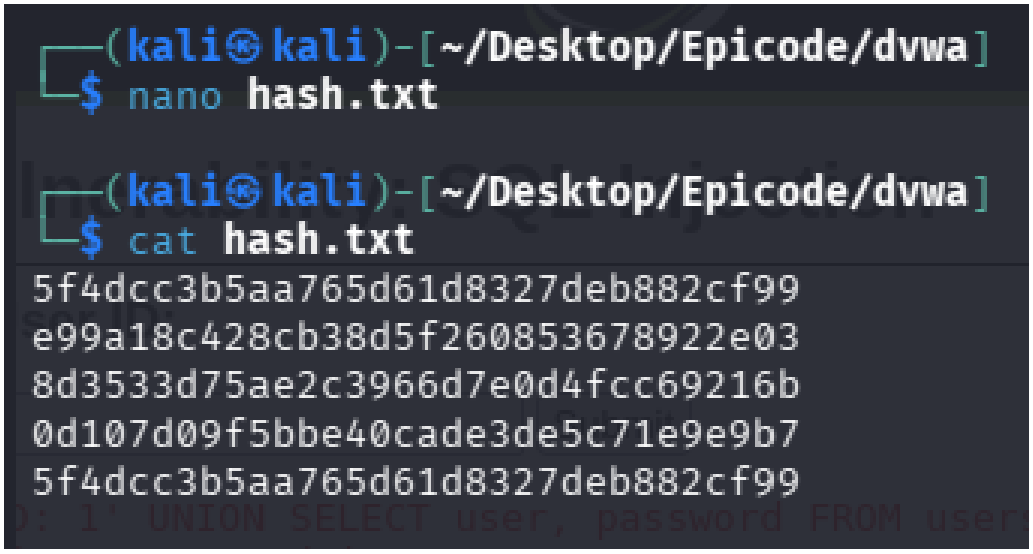


2 Che cos'è un hash MD5

Un hash MD5 trasforma una password in una stringa di 32 caratteri esadecimali. Non è una password leggibile e non è una cifratura da invertire. Nel laboratorio, John confronta gli hash trovati con gli hash generati da possibili password. Il formato raw-md5 indica che i valori sono hash MD5 semplici.

3 Preparazione del file hash.txt

Il file hash.txt contiene un hash per riga. Per essere riconosciuto da John, ogni riga deve contenere esclusivamente il valore hash, senza numeri iniziali o spazi. Questo file è l'input del controllo.



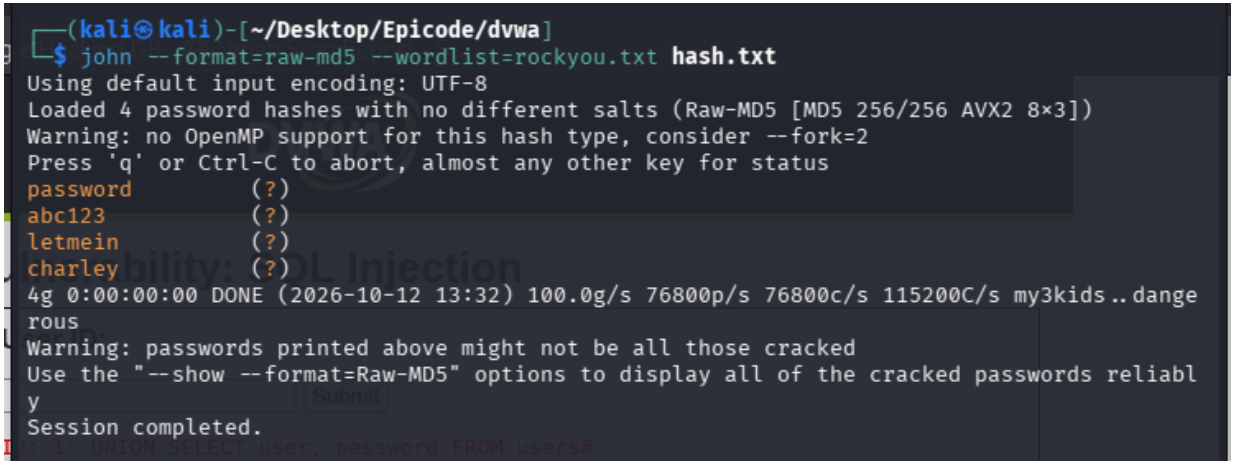
4 John the Ripper e il dizionario RockYou

John the Ripper è uno strumento di verifica della sicurezza delle password. Per ogni parola candidata del dizionario RockYou calcola l'hash MD5 e lo confronta con i valori in hash.txt. Il dizionario RockYou era disponibile in formato compresso nel sistema ed è stato decompresso localmente in rockyou.txt.

Comando eseguito:

```
john --format=raw-md5 --wordlist=rockyou.txt hash.txt
```

L'opzione --format=raw-md5 specifica il formato degli hash; --wordlist=rockyou.txt indica il dizionario; hash.txt è il file da controllare.

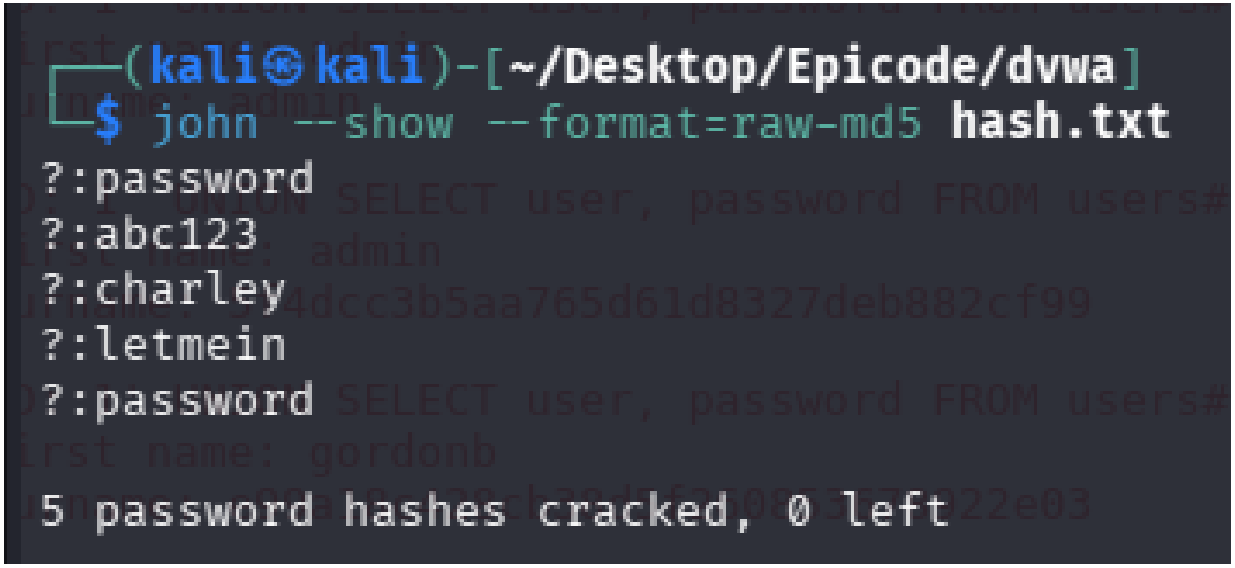


5 Risultato del cracking

Durante l'esecuzione John ha caricato quattro hash distinti, perché uno dei cinque valori era duplicato. La sessione è terminata correttamente. Con il comando seguente sono stati visualizzati tutti i risultati nell'ordine del file:

```
john --show --format=raw-md5 hash.txt
```

Le cinque password ottenute sono: password, abc123, charley, letmein e password. Il riepilogo indica cinque password recuperate e nessun hash rimasto senza risultato.



6 Controprova: dalla password all'hash

La controprova non inverte MD5. Si parte invece da una password in chiaro, se ne ricalcola l'hash MD5 e lo si confronta con quello presente nel file. Il comando echo -n "password" | md5sum ha prodotto l'hash 5f4dcc3b5aa765d61d8327deb882cf99; lo stesso procedimento è stato applicato alle quattro password distinte. I risultati coincidono con gli hash ottenuti da DVWA.



7 Parte facoltativa: risposta a WannaCry

WannaCry è un ransomware che cifra i file e può diffondersi in rete tramite il servizio SMB di Windows. In un incidente reale, l'obiettivo iniziale è contenere la diffusione e preservare le informazioni utili alla gestione dell'evento.

Intervento immediato

Il PC sospetto deve essere isolato subito: scollegamento del cavo di rete, disattivazione del Wi-Fi e nessun collegamento di supporti USB o backup. Il team IT e il responsabile dell'incidente devono essere avvisati; si annotano ora, sistema coinvolto e sintomi osservati. Eventuali backup offline vengono protetti e mantenuti separati dalla macchina infetta.

Possibilità di recupero e messa in sicurezza

Formattazione e reinstallazione pulita. Pro: è la scelta più affidabile per eliminare componenti dannosi e ripartire da una configurazione aggiornata. Contro: richiede tempo e può causare perdita dei dati non presenti in backup sicuri.

Ripristino da un backup precedente all'infezione. Pro: permette di recuperare dati e servizi più velocemente. Contro: il backup deve essere verificato, precedente all'infezione e ripristinato su un sistema già pulito; il lavoro successivo alla data del backup può andare perso.

Strumenti specializzati di rimozione malware. Pro: possono ridurre i tempi di analisi e aiutare a individuare il malware. Contro: dopo un ransomware non garantiscono da soli che il sistema sia completamente affidabile.

Aggiornamento a un sistema operativo supportato. Pro: consente di ricevere aggiornamenti di sicurezza e riduce l'esposizione a vulnerabilità note. Contro: richiede pianificazione, compatibilità di applicazioni e tempo di migrazione.

Prevenzione dopo il recupero

Prima del rientro in rete si applicano gli aggiornamenti di sicurezza, si eliminano protocolli obsoleti come SMBv1, si attiva una protezione endpoint, si separano le reti quando necessario e si mantengono backup offline verificati con regolarità.

Conclusione

L'esercizio dimostra che un hash MD5 debole, associato a password comuni, può essere individuato con un attacco a dizionario. La controprova conferma il risultato confrontando gli hash ricalcolati. La parte facoltativa evidenzia che, davanti a un ransomware, la priorità è isolare il sistema e scegliere un recupero verificato e sicuro.